

WEEK 9 INVESTIGATION

Cerber Ransomware Infection via RIG Exploit Kit

Team Members: Jobayer & Ari

Date: 04/03/2026 | Course: Network Forensics

Assignment: Team PCAP Analysis — Week 9

Abstract

Investigation overview and key findings

This investigation analyzed a PCAP file captured on 2017-01-27 containing network traffic from host 172.16.4.193 (STEWIE-PC), a Windows 7 machine on the 172.16.4.0/24 network.

STEWIE-PC was infected with Cerber ransomware following a drive-by download attack. The infection chain began at a compromised WordPress site (www.homeimprovement.com), proceeded through an evil redirector (retrotip.visionurbana.com.ve), and delivered the RIG exploit kit via C2 server tyu.benme.com (194.87.234.129).

Flash exploits and Windows executables were dropped. The ransomware loaded a payment portal and displayed a Bitcoin ransom demand. The full attack chain was captured in under 7 minutes across 6,033 packets.

Key tools used: Security Onion (Suricata IDS), Wireshark, NetworkMiner, and VirusTotal. All IOCs were validated; false positive probability is extremely low.

6,033

Total Packets

7 min

Attack Duration

6

Attack Stages

High

Alert Confidence

Introduction

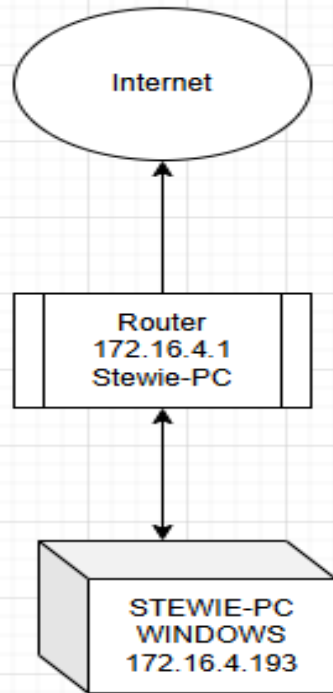
Background, objective, scope, and toolset

Background & Objective
■ A PCAP file from 2017-01-27 was analyzed to investigate a reported malware infection on an internal Windows host. ■ Objective: Identify the malware type, trace the full attack chain from initial access to ransomware deployment, extract all IOCs, and evaluate IDS alert accuracy. ■ Scope: Single host 172.16.4.193 (STEWIE-PC) on the 172.16.4.0/24 network. Timeframe: 22:53–23:00 UTC. 6,033 packets captured. No lateral movement detected.

Tools Used
Security Onion (Suricata IDS) Alert dashboard — grouped alerts by source IP and signature severity
Wireshark / PCAP Analysis Packet-level inspection; HTTP stream reconstruction; export objects
NetworkMiner Host enumeration, OS fingerprinting, MAC addresses, session mapping
VirusTotal IOC validation — IPs, domains, and file hashes cross-referenced against 94 vendors

The Network

Internal topology and external connections identified from PCAP



Network Summary

Subnet:

172.16.4.0/24 (SOHO flat network)

Victim Host:

STEWIE-PC — 172.16.4.193
Windows 7, Dell NIC
MAC: 5C:26:0A:02:A8:E4

Gateway:

172.16.4.1 — DNS + NAT

C2 Server:

tyu.benme.com
194.87.234.129 (RU)

Dropper:

spotsbill.com
5.188.223.104

Ransom Portal:

p27dokhpz2n7nvgr
.1jw2lx.top

Methodology

Analytical process used to reconstruct the attack

1

Alert Triage

Reviewed Security Onion Alerts dashboard. Grouped alerts by source IP and rule name. Identified highest-severity Suricata signatures (RIG EK ×15, Evil Redirector, Cerber Ransomware) as the starting point.

2

OSINT Validation

Queried each IOC (IPs and domains) in VirusTotal. Obtained independent vendor verdicts to confirm or rule out false positives. Key IPs verified against 94-vendor engine consensus.

3

PCAP Deep-Dive

Applied Wireshark display filters (ip.addr, http, dns) to isolate malicious traffic. Reconstructed HTTP streams to identify payload delivery and C2 beaconing. Used Export Objects to extract dropped executables.

4

Host Enumeration

Loaded PCAP into NetworkMiner to identify hostnames, OS fingerprints, MAC addresses, and all outgoing sessions from the infected host (69 total sessions mapped).

5

IOC Extraction

Extracted all IP addresses, domains, Bitcoin wallet addresses, victim GUIDs, file hashes, and MITRE ATT&CK technique mappings from correlated evidence across all tools.

6

Timeline Construction

Cross-referenced packet timestamps, DNS queries, HTTP requests, and IDS alerts to build a precise UTC timeline from initial access (22:53) through ransomware portal load (22:55).

Timeline of Events

All times UTC — 2017-01-27 | Capture: 22:53:08 – 23:00 UTC

Attack Timeline

Time (UTC)	Stage	Alert / Event	Description
22:55:27	Initial Access	DNS Query to .top domain	Connection to suspicious domain
22:55:27	Initial Access	HTTP Request to .top domain	Web request confirms access
22:55:47	Redirection	Exploit Kit Redirector	Redirected to exploit kit
22:55:04–22:56:13	Exploit Kit	RIG EK Landing	Fingerprinting and staging
22:54:42–22:56:13	Exploitation	RIG EK URI Struct	Multiple exploit attempts
22:55:27	Post-Exploitation	Cerber Domain Lookup	Ransomware communication
Ongoing	Profiling	UA-CPU Header	System fingerprinting

Indicators of Compromise (IOCs)

All IOCs extracted from PCAP and validated via VirusTotal

Indicators of Compromise (IOCs)

Type	Example	Description / Relevance
Domain	.top domain	Suspicious domain used for initial access
Alert	Exploit Kit Redirector	Indicates redirection to malicious infrastructure
Exploit Kit	RIG EK	Used to deliver exploits to victim system
URI Pattern	RIG EK URI Struct	Identifies exploit kit traffic patterns
Malware	Cerber Domain Lookup	Indicates ransomware communication

Additional IOCs

Bitcoin:

17gd1msp5FnMcEMF
1MitTNSsYs7w7AQyCt

GUID:

EE7E-AD39-7D8C
-080C-18BF

MITRE:

T1189 Drive-by
T1203 Client Exploit
T1071 App Layer C2
T1486 Data Encrypted

Malware:

Cerber Ransomware
RIG Exploit Kit

Analysis: Drive-By Attack to Ransomware Sequence

Step	Stage	Domain / Indicator	Activity	Purpose / Outcome
1	Initial Access	homeimprovement.com	User visits site	Entry point (benign/malvertising)
2	Redirection	tyu.benme.com	Silent redirect	Attacker-controlled redirect
3	Exploit Kit Landing	spotsbill.com	Landing page loads	System fingerprinting (EK staging)
4	Infrastructure	api.blockcypher.com	Background requests	Blends with legit traffic
5	Exploit Delivery	p27d0khpz2n7nvgr.1jw2lx.top	Multiple requests	RIG exploit kit delivery
6	Exploitation	RIG EK URI Struct	Exploit triggered	Vulnerability exploited
7	Payload Assist	fpdownload2.macromedia.com	Flash interaction	Exploit support
8	Payload Download	tyu.benme.com	Executable delivered	Malware downloaded
9	C2 Communication	p27d0khpz2n7nvgr.1jw2lx ton	Beaconing activity	Attacker communication

Analysis & Interpretation

Attack flow, exfiltrated data, and false positive assessment

Attack Flow Summary

The attack targeted STEWIE-PC (172.16.4.193) via a drive-by download. The user visited the compromised site `homeimprovement.com`, which silently injected an iframe pointing to `tyu.benme.com` (RIG Exploit Kit C2).

The RIG EK fingerprinted the browser (SeaMonkey UA string with WOW64, .NET CLR, Media Center 6.0) and delivered three 16kB Flash exploits and two Windows executables (165kB, 500kB) via `application/x-msdownload`.

After payload drop, the host resolved the randomized `.top` domain `p27dokhpz2n7nvgr.1jw2lx.top` (198.105.121.50) — the Cerber ransom portal. Victim GUID `EE7E-AD39-7D8C-080C-18BF` was assigned and a Bitcoin payment page loaded.

Files Downloaded: Flash exploits ×3 (16kB each), executables ×2 from `tyu.benme.com`. Data exfiltrated: browser UA, plugin flags, system fingerprint via encoded GET parameters.

MITRE ATT&CK Techniques

- | | |
|-------|---|
| T1189 | Drive-by Compromise — <code>homeimprovement.com</code> iframe injection |
| T1203 | Client Exploitation — Flash Player exploited by RIG EK |
| T1071 | App Layer Protocol — HTTP C2 beaconing to <code>tyu.benme.com</code> |
| T1486 | Data Encrypted for Impact — Cerber file encryption + ransom demand |

False Positive Assessment

15× RIG EK URI Struct alerts — repetition at scale rules out coincidence. Multiple independent Suricata rules corroborate the same event chain. All critical rule confidence ratings: High.

`spotsbill.com`: 11/94 VT vendors flagged — not a false positive. Three IPs appear clean on VT but were analyzed 4–7 years ago; IP reassignment likely explains the discrepancy. Overall false positive probability: extremely low.

Evidence of Infection — C2 Server Validation

VirusTotal confirms 194.87.234.129 as RIG Exploit Kit C2

Security Onion

194.87.234.129

1 / 94
Community Score

1/94 security vendor flagged this IP address as malicious

194.87.234.129 (194.87.234.0/23)
AS 48347 (JSC Mediasoft ekspert)

RU
Last Analysis Date
3 months ago

Reanalyze More

DETECTION DETAILS RELATIONS COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

Webroot	Malicious	Abusix	Clean
Acronis	Clean	ADMINUSLabs	Clean

Finding

VirusTotal flagged 194.87.234.129 as malicious (Webroot: Malicious). This IP belongs to JSC Mediasoft ekspert (Russia, AS 48347). Suricata independently identified this as the RIG EK C2 landing page with High severity. Corroborated by Security Onion alert: ET EXPLOIT_KIT RIG EK Landing.

Fig 1: VirusTotal report for 194.87.234.129 (tyu.benme.com) — confirms RIG EK C2 server, flagged malicious by Webroot. Corroborated by Suricata ET EXPLOIT_KIT RIG EK Landing alert.

Evidence — Evil Redirector & Payload Delivery

Stages 1–3: compromised WordPress → evil redirect → RIG EK payload drop

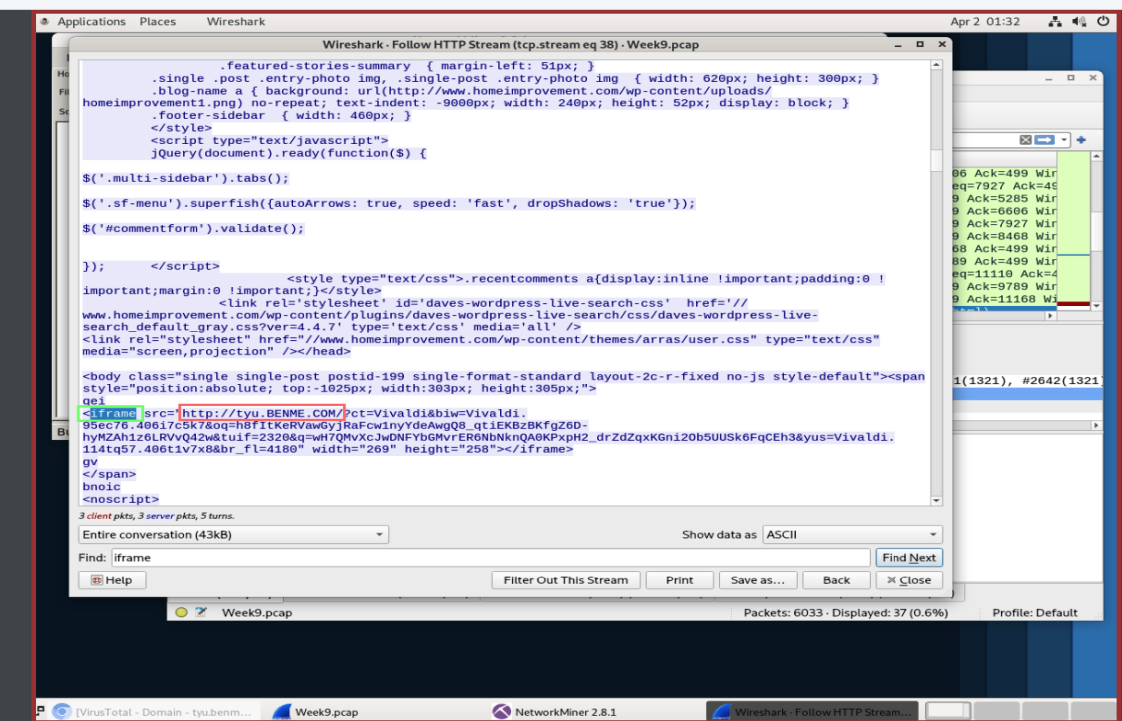


Fig 2: Wireshark HTTP stream — homeimprovement.com response containing iframe src pointing to http://tyu.BENME.COM — the RIG EK C2 redirector. This confirms Stage 1→2 of the attack chain.

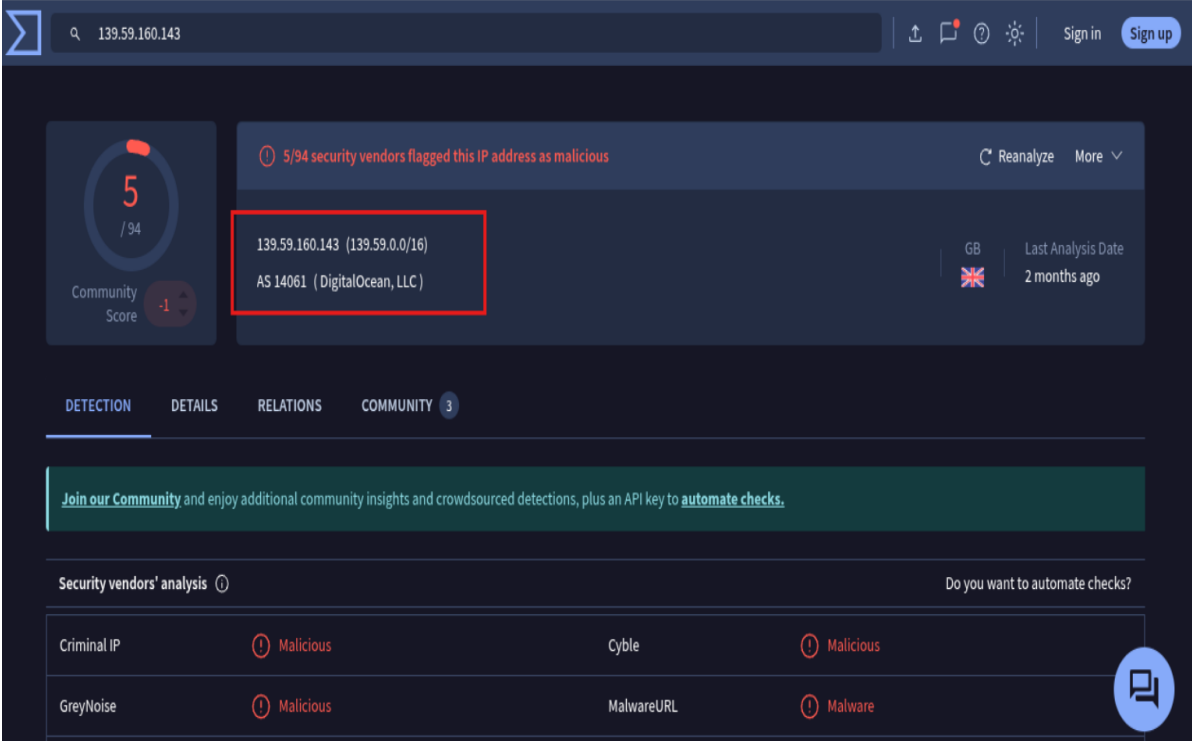


Fig 3: Wireshark HTTP Export Objects — tyu.benme.com serving application/x-msdownload (executable) and application/x-shockwave-flash (exploit). Confirms payload drop via RIG EK.

Evidence — Ransomware DNS Beacon

Stage 5: DNS query for Cerber ransom portal domain

5141	139.352932	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=5285 Ack=355 Win=28160 Len=1321 [TCP segment of a
5142	139.353044	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=6606 Ack=355 Win=28160 Len=1321 [TCP segment of a
5143	139.353155	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=7927 Ack=355 Win=28160 Len=1321 [TCP segment of a
5144	139.353165	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=3964 Win=66048 Len=0
5145	139.353181	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=5285 Win=66048 Len=0
5146	139.353190	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=6606 Win=66048 Len=0
5147	139.353283	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=9248 Ack=355 Win=28160 Len=1321 [TCP segment of a
5148	139.353411	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=10569 Ack=355 Win=28160 Len=1321 [TCP segment of a
5149	139.353416	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=7927 Win=66048 Len=0
5150	139.353431	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=9248 Win=66048 Len=0
5151	139.353522	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=11890 Ack=355 Win=28160 Len=1321 [TCP segment of a
5152	139.353914	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=13211 Win=61952 Len=0
5153	139.356169	172.16.4.193	107.23.24.131	TCP	60 [TCP Window Update] 49211 → 80 [ACK] Seq=355 Ack=13211 Win=66048 Len=0
5154	139.359498	172.16.4.193	172.16.4.255	NBNS	92 Name query NB WPAD<00>
5155	139.429854	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=13211 Ack=355 Win=28160 Len=1321 [TCP segment of a
5156	139.430101	107.23.24.131	172.16.4.193	TCP	1375 80 → 49211 [ACK] Seq=14532 Ack=355 Win=28160 Len=1321 [TCP segment of a
5157	139.431655	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=15853 Win=66048 Len=0
5158	139.435367	107.23.24.131	172.16.4.193	HTTP/JSON	730 HTTP/1.1 200 OK , JavaScript Object Notation (application/json)
5159	139.435616	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=355 Ack=16529 Win=65280 Len=0
5160	139.452181	172.16.4.193	107.23.24.131	HTTP	436 GET /v1/btc/main/txs/3147f75b480ec1b0c33ab3cared091b100f7e77221b221d49
5161	139.534817	107.23.24.131	172.16.4.193	HTTP/JSON	1242 HTTP/1.1 200 OK , JavaScript Object Notation (application/json)
5162	139.535251	172.16.4.193	107.23.24.131	TCP	60 49211 → 80 [ACK] Seq=737 Ack=17717 Win=66048 Len=0
5163	139.560617	172.16.4.193	172.16.4.1	DNS	87 Standard query 0xcd6c A p27dokhpz2n7nvgr.1jw2lx.top
5164	139.661445	172.16.4.1	172.16.4.193	DNS	103 Standard query response 0xcd6c A p27dokhpz2n7nvgr.1jw2lx.top A 198.105.
5165	139.662635	172.16.4.193	198.105.121.50	TCP	66 80 → 49212 [SYN] Seq=0 Win=0 Len=0 MSS=1460 WS=256 SACK_PERM=1
5166	139.838168	198.105.121.50	172.16.4.193	TCP	66 80 → 49212 [SYN, ACK] Seq=0 Ack=1 Win=14600 Len=0 MSS=1321 SACK_PERM=1
5167	139.838568	172.16.4.193	198.105.121.50	TCP	60 49212 → 80 [ACK] Seq=1 Ack=1 Win=66048 Len=0
5168	139.838813	172.16.4.193	198.105.121.50	HTTP	395 GET /EE7E-AD39-7D8C-080C-18BF?iframe&_id=1485557725652 HTTP/1.1
5169	140.036455	198.105.121.50	172.16.4.193	TCP	54 80 → 49212 [ACK] Seq=1 Ack=342 Win=15744 Len=0
5170	140.108739	172.16.4.193	172.16.4.255	NBNS	92 Name query NB WPAD<00>

Fig 4: Wireshark packet view — packet 5163 shows a DNS Standard Query for p27dokhpz2n7nvgr.1jw2lx.top (highlighted row), immediately followed by resolution to 198.105.121.50. This confirms the ransomware payment portal lookup after successful infection. Also visible: prior DNS queries to all malicious domains in sequence.

Key Finding: The DNS sequence (homeimprovement.com → visionurbana → tyu.benme.com → spotsbill.com → api.blockcypher.com → p27dokhpz2n7nvgr.1jw2lx.top) maps the complete 6-stage attack chain directly from packet timestamps.

Evidence — Malware Executable Download

Stage 3: application/x-msdownload payload from tyu.benme.com

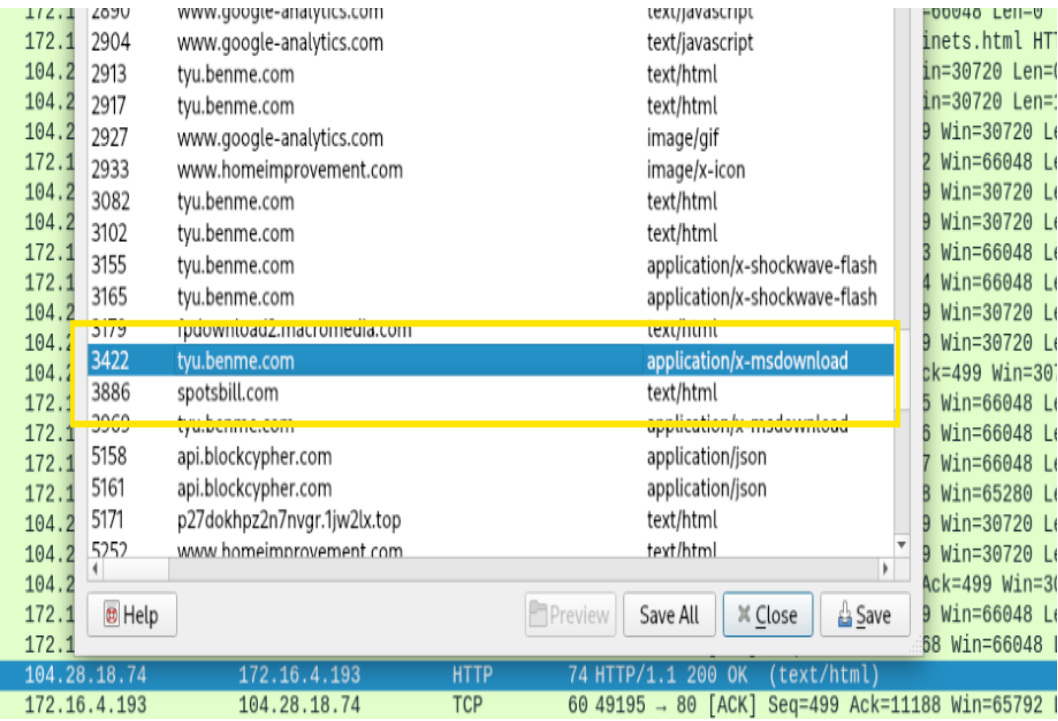


Fig 5: HTTP stream (tcp.stream eq 52) — tyu.benme.com response with Content-Type: application/x-msdownload (166kB). The binary payload (obfuscated .exe) confirms the malware executable was successfully delivered to STEWIE-PC.

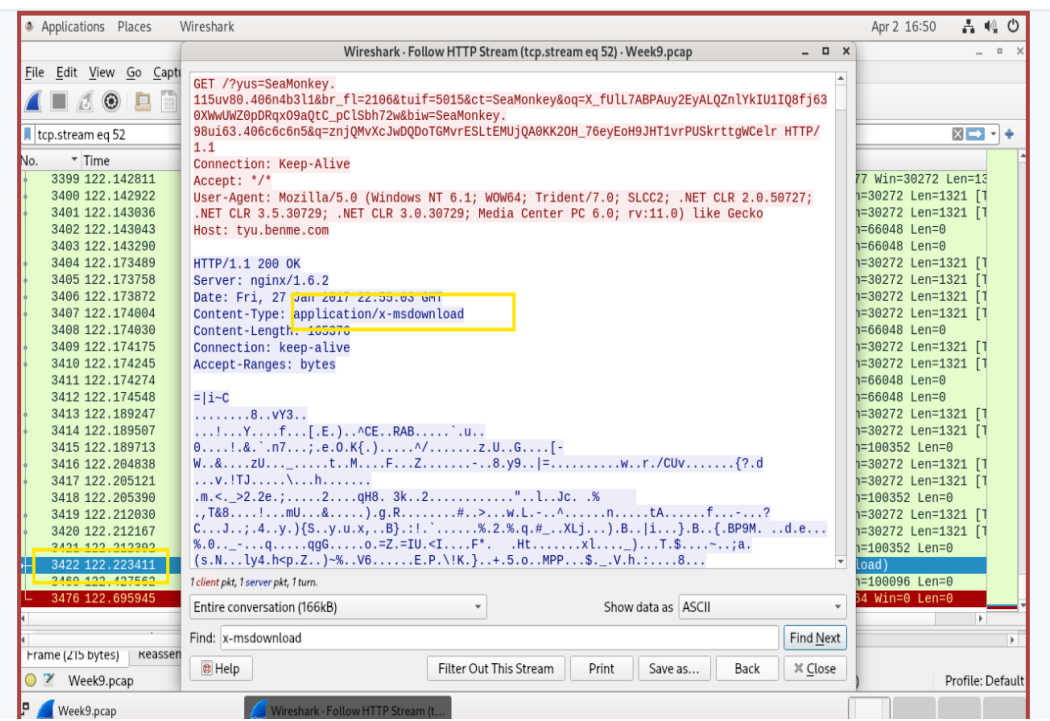


Fig 6: Wireshark HTTP Export Objects — tyu.benme.com listed as source for application/x-msdownload (highlighted). spotsbill.com also visible, serving text/html (secondary dropper). Both confirmed malicious by VirusTotal.

Evidence — Suricata IDS Alerts

Security Onion confirming RIG EK and Cerber Ransomware signatures

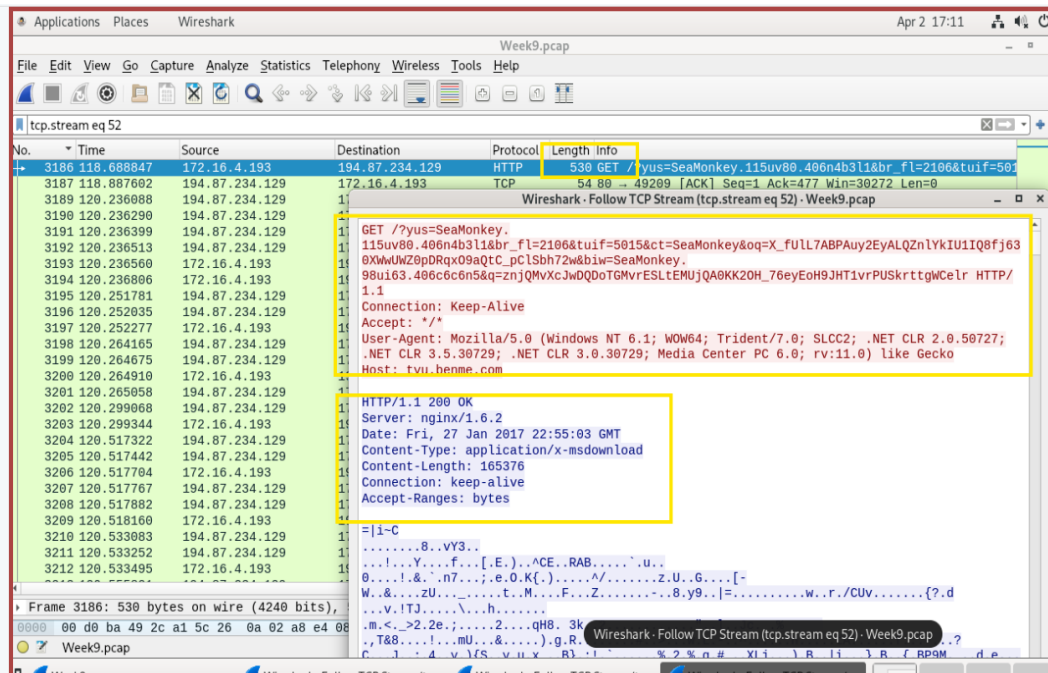


Fig 7: Security Onion Suricata alert metadata — showing RIG EK alert triggered by traffic from 139.59.160.143 (evil redirector). High severity, Client_Endpoint category. Confirms Stage 1 → Stage 2 redirect.

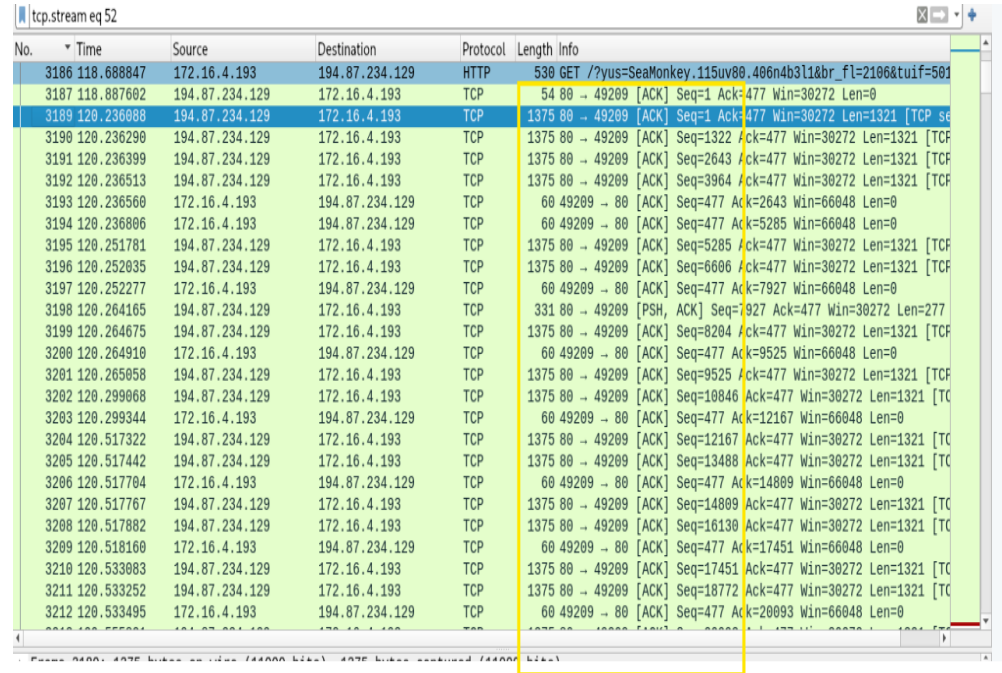
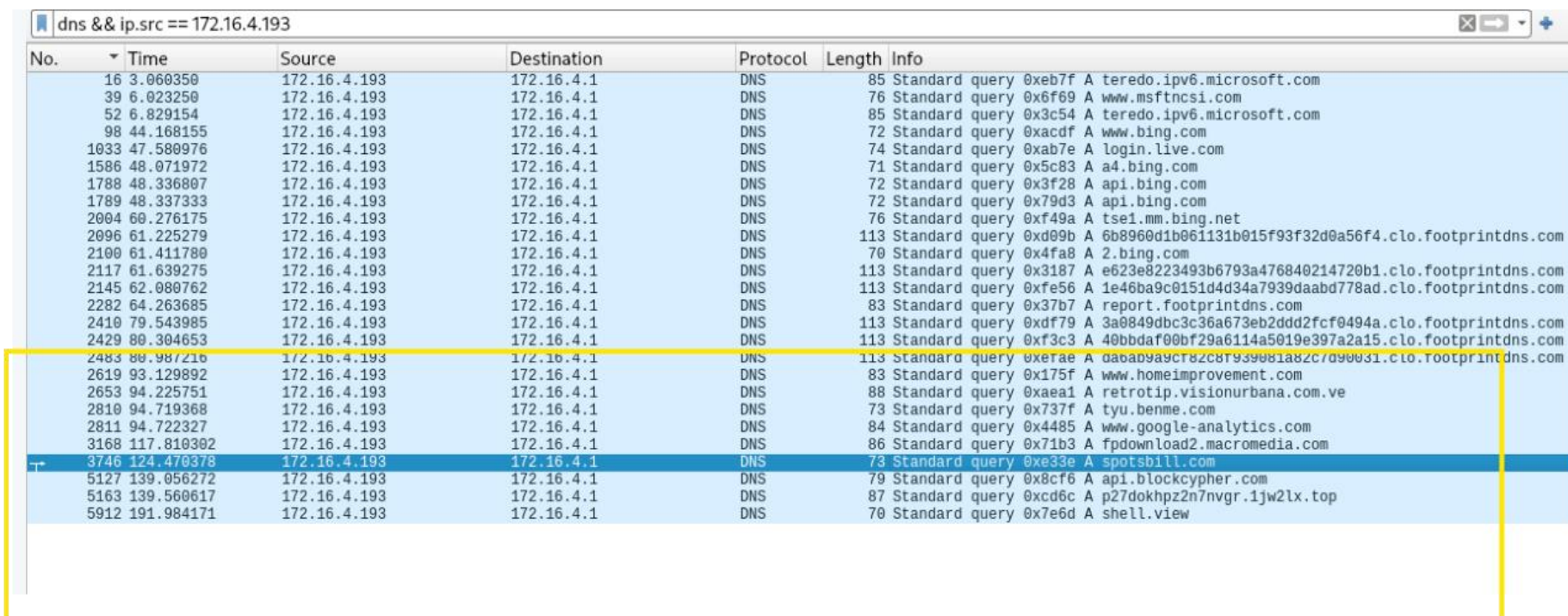


Fig 8: Security Onion — ET MALWARE Ransomware/Cerber alert. DNS_Onion_Query tag confirms ransomware domain lookup. Malware family: Ransomware_Cerber. MITRE ATT&CK: T1486 (Data Encrypted for Impact), TA0040 Impact.

Evidence — Complete DNS Query Sequence

All outbound DNS requests from STEWIE-PC confirming the attack chain order

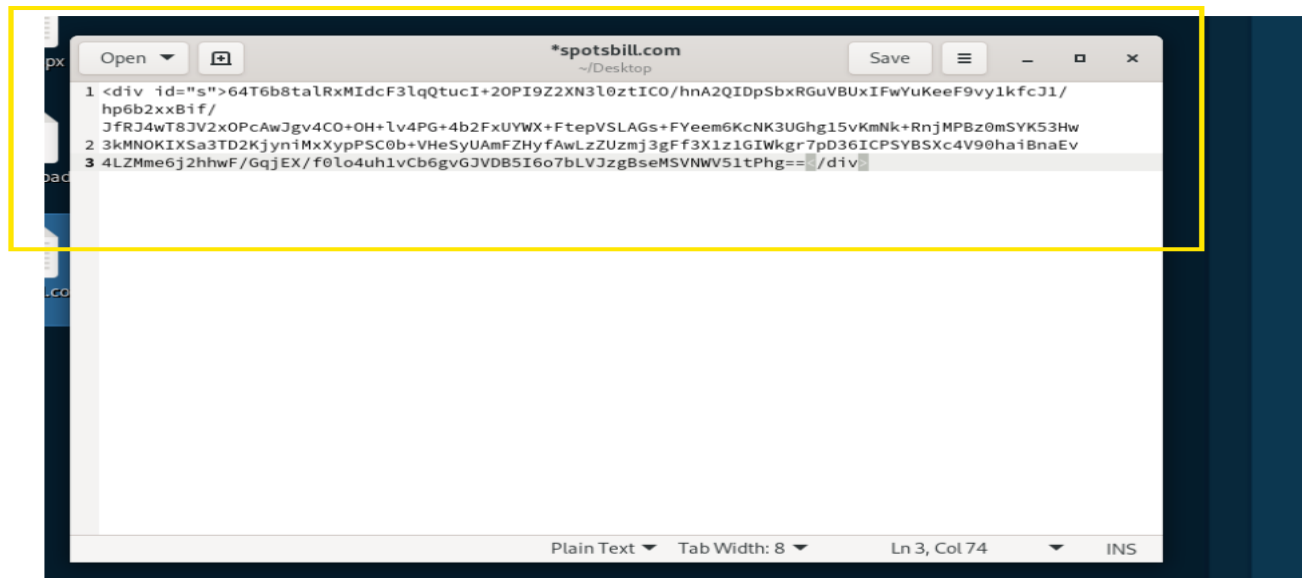


No.	Time	Source	Destination	Protocol	Length	Info
16	3.060350	172.16.4.193	172.16.4.1	DNS	85	Standard query 0xeb7f A teredo.ipv6.microsoft.com
39	6.023250	172.16.4.193	172.16.4.1	DNS	76	Standard query 0x6f69 A www.msftncsi.com
52	6.829154	172.16.4.193	172.16.4.1	DNS	85	Standard query 0x3c54 A teredo.ipv6.microsoft.com
98	44.168155	172.16.4.193	172.16.4.1	DNS	72	Standard query 0xacdf A www.bing.com
1033	47.580976	172.16.4.193	172.16.4.1	DNS	74	Standard query 0xab7e A login.live.com
1586	48.071972	172.16.4.193	172.16.4.1	DNS	71	Standard query 0x5c83 A a4.bing.com
1788	48.336807	172.16.4.193	172.16.4.1	DNS	72	Standard query 0x3f28 A api.bing.com
1789	48.337333	172.16.4.193	172.16.4.1	DNS	72	Standard query 0x79d3 A api.bing.com
2004	60.276175	172.16.4.193	172.16.4.1	DNS	76	Standard query 0xf49a A tse1.mm.bing.net
2096	61.225279	172.16.4.193	172.16.4.1	DNS	113	Standard query 0xd09b A 6b8960d1b061131b015f93f32d0a56f4.clo.footprintdns.com
2100	61.411780	172.16.4.193	172.16.4.1	DNS	70	Standard query 0x4fa8 A 2.bing.com
2117	61.639275	172.16.4.193	172.16.4.1	DNS	113	Standard query 0x3187 A e623e8223493b6793a476840214720b1.clo.footprintdns.com
2145	62.080762	172.16.4.193	172.16.4.1	DNS	113	Standard query 0xfe56 A 1e46ba9c0151d4d34a7939daabd778ad.clo.footprintdns.com
2282	64.263685	172.16.4.193	172.16.4.1	DNS	83	Standard query 0x37b7 A report.footprintdns.com
2410	79.543985	172.16.4.193	172.16.4.1	DNS	113	Standard query 0xdf79 A 3a0849dbc3c36a673eb2ddd2fcf0494a.clo.footprintdns.com
2429	80.304653	172.16.4.193	172.16.4.1	DNS	113	Standard query 0xf3c3 A 40bbdaf00bf29a6114a5019e397a2a15.clo.footprintdns.com
2483	80.987216	172.16.4.193	172.16.4.1	DNS	113	Standard query 0xerae A 0aab9a9c82c87939081a82c7090031.clo.footprintdns.com
2619	93.129892	172.16.4.193	172.16.4.1	DNS	83	Standard query 0x175f A www.homeimprovement.com
2653	94.225751	172.16.4.193	172.16.4.1	DNS	88	Standard query 0xaea1 A retrotip.visionurbana.com.ve
2810	94.719368	172.16.4.193	172.16.4.1	DNS	73	Standard query 0x737f A tyu.benme.com
2811	94.722327	172.16.4.193	172.16.4.1	DNS	84	Standard query 0x4485 A www.google-analytics.com
3168	117.810302	172.16.4.193	172.16.4.1	DNS	86	Standard query 0x71b3 A fpdownload2.macromedia.com
3746	124.470378	172.16.4.193	172.16.4.1	DNS	73	Standard query 0xe33e A spotsbill.com
5127	139.056272	172.16.4.193	172.16.4.1	DNS	79	Standard query 0x8cf6 A api.blockcypher.com
5163	139.560617	172.16.4.193	172.16.4.1	DNS	87	Standard query 0xcd6c A p27dokhpn2n7nvgr.1jw2lx.top
5912	191.984171	172.16.4.193	172.16.4.1	DNS	70	Standard query 0x7e6d A shell.view

Fig 9: Wireshark DNS filter (dns && ip.src == 172.16.4.193) — showing the complete query timeline. Highlighted rows confirm all 6 malicious domains queried in sequence: homeimprovement.com → retrotip.visionurbana.com.ve → tyu.benme.com → spotsbill.com → api.blockcypher.com → p27dokhpn2n7nvgr.1jw2lx.top. This single view proves the full attack chain.

Evidence — spotsbill.com: Staging Server

Stage 4: Base64-encoded payload response confirms secondary dropper role



```
1 <div id="s">64T6b8ta1RxMIdcF3lqQtucI+20PI9Z2XN3l0ztICO/hnA2QIDpSbxRGUvBUxIFwYuKeeF9vy1kfcJ1/
hp6b2xxBif/
2 JfRJ4wT8Jv2x0PcAwJgv4CO+0H+lv4PG+4b2FxUYWX+FtepVSLAGs+FYeem6KcNK3UGhg15vKmNk+RnjMPBz0mSYK53Hw
3 3kMNOKIXSa3TD2KjyniMxXypPSC0b+VHeSyUAmFZHyfAwLzZUzmj3gFf3X1z1GIWkgr7pD36ICPSYBSXc4V90ha1BnaEv
4 4LZMme6j2hhwF/GqjEX/f0lo4uh1vCb6gvG3VDB5I6o7bLVJzgBseMSVNWV51tPhg==</div>
```

Fig 10: Decoded HTTP response from spotsbill.com — a Base64-encoded blob inside a `<div id='s'>` tag. No HTML structure, images, or scripts. Confirms machine-to-machine payload retrieval, not normal web content.

Analysis

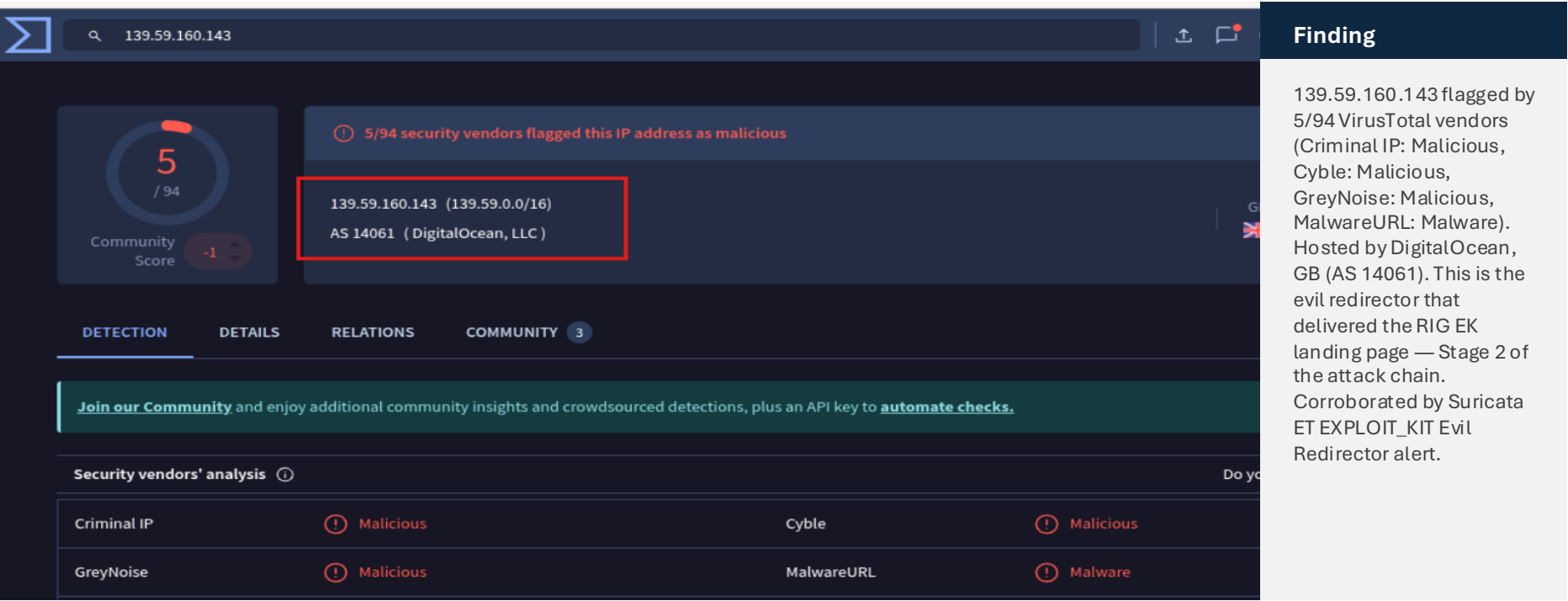
spotsbill.com returned a `<div>` element containing a large Base64-encoded string — characteristics: A–Z, a–z, 0–9, +, / with no spaces or HTML structure.

This is NOT user-facing content. This is machine-to-machine communication — a payload chunk or configuration data retrieved by the ransomware after initial execution.

Role: Secondary staging server. Returns encoded payload data, not C2 commands. Confirmed malicious: 11/94 VirusTotal vendors (Kaspersky, BitDefender, Fortinet).

Evidence — Evil Redirector IP Validation

VirusTotal confirms 139.59.160.143 as malicious — evil redirector (Stage 2)



Finding

139.59.160.143 flagged by 5/94 VirusTotal vendors (Criminal IP: Malicious, Cyble: Malicious, GreyNoise: Malicious, MalwareURL: Malware). Hosted by DigitalOcean, GB (AS 14061). This is the evil redirector that delivered the RIG EK landing page — Stage 2 of the attack chain. Corroborated by Suricata ET EXPLOIT_KIT Evil Redirector alert.

Fig 11: VirusTotal report for 139.59.160.143 (retrotip.visionurbana.com.ve) — 5/94 vendors flagged malicious. Confirms this IP as the evil redirector (Stage 2). Suricata independently triggered ET EXPLOIT_KIT Evil Redirector Leading to EK alert at High severity.

Evidence — VirusTotal: Ransom Portal Domain

p27dokhpz2n7nvgr.1jw2lx.top — 13/94 vendors flagged malicious

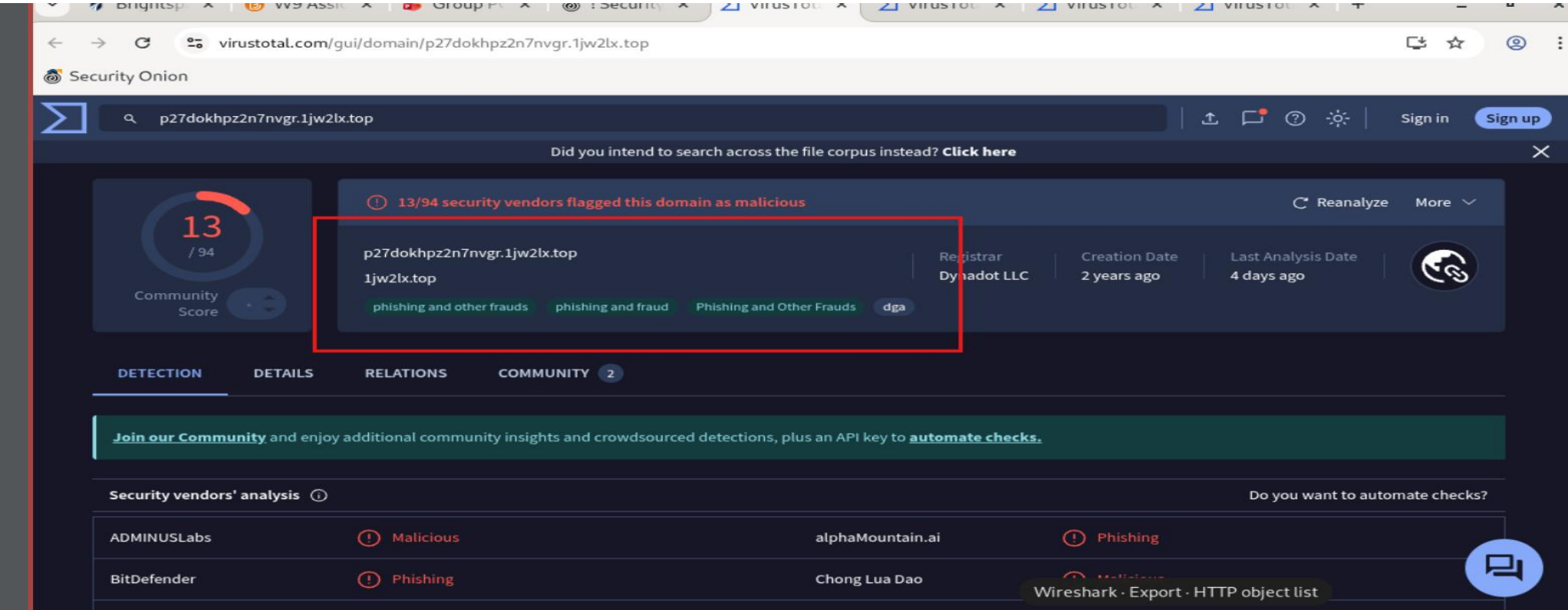


Fig 12: VirusTotal for p27dokhpz2n7nvgr.1jw2lx.top — 13/94 vendors flagged (ADMINUSLabs: Malicious, alphaMountain.ai: Phishing, BitDefender: Phishing, Chong Lua Dao: Malicious). Tagged: phishing and other frauds, DGA. Registered via Dynadot LLC. This is the Cerber ransomware payment portal — confirms Stage 5 of the attack.

Evidence — Compromised HTML Payload Rendered

Stage 1: homeimprovement.com local copy shows injected 'bnoic' tag

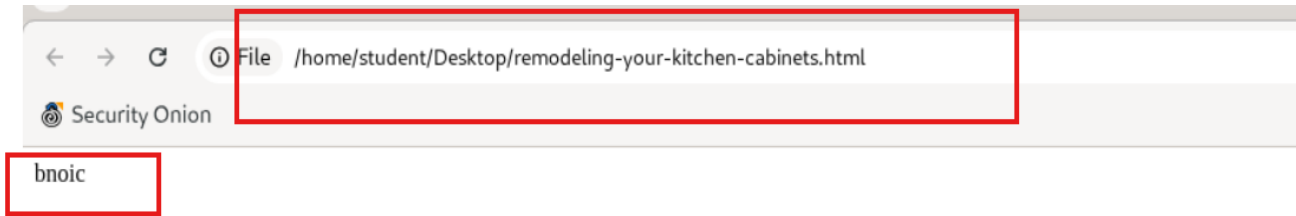


Fig 13: Rendered HTML from homeimprovement.com (saved locally from PCAP). The page shows only 'bnoic' — an injected non-standard tag. Legitimate content stripped by attacker; only the redirect iframe executes. Confirms the website was actively compromised (Stage 1).

Significance

The remodeling-your-kitchen-cabinets.html file was extracted from the PCAP and rendered locally. It shows an almost-blank page with only 'bnoic' visible — a non-standard tag injected by the attacker.

This confirms the WordPress site's content was maliciously modified. The visible page contains no legitimate content; the injected code only executes the redirect to tyu.benme.com via the hidden iframe.

This is direct proof of Stage 1: the compromised entry point.

Non-Technical Summary

Plain-language explanation for non-forensic readers

What happened?

A staff member's computer (STEWIE-PC) was infected with ransomware after visiting a home improvement website that had been secretly hacked by attackers.

How did it happen?

The hacked website silently redirected the browser to a malicious server, which exploited Adobe Flash Player to automatically install the Cerber ransomware — without the user clicking anything suspicious.

What did the ransomware do?

The ransomware encrypted the victim's files and displayed a payment page demanding cryptocurrency in exchange for the decryption key. It also sent information about the infected computer back to the attacker's servers.

Was it contained?

Yes. No other computers on the internal network were affected. The infection was isolated to STEWIE-PC. However, the encrypted files may be unrecoverable without a clean backup.

Conclusions

Key findings proven through forensic analysis

✓ STEWIE-PC (172.16.4.193) was infected with Cerber ransomware on 2017-01-27 via a drive-by download attack, confirmed by Suricata, Wireshark, NetworkMiner, and VirusTotal.

✓ The infection vector was the RIG Exploit Kit delivered through a compromised WordPress site (homeimprovement.com) and an evil redirector (retrotip.visionurbana.com.ve).

✓ Malicious files downloaded via HTTP: Windows executables (165kB ×2, 500kB) and Flash exploits (16kB ×3) from tyu.benme.com (194.87.234.129) — confirmed RIG EK C2 server.

✓ The Cerber payment portal at p27dokhpz2n7nvgr.1jw2lx.top was fully loaded. Victim GUID EE7E-AD39-7D8C-080C-18BF was assigned and Bitcoin wallet 17gd1msp5FnMcEMF1Mit... was presented.

✓ Browser fingerprint and system info were exfiltrated to the C2 server via encoded GET parameters. External IP identified via msftncsi.com (Windows auto-check).

✓ No lateral movement detected. Infection contained to a single machine on the 172.16.4.0/24 network. False positive probability: extremely low — multiple independent signatures corroborate.

Recommendations

Remediation steps tied to specific findings

1

Isolate & Reimage STEWIE-PC

Finding: Cerber confirmed. Immediately isolate 172.16.4.193 from the network. Wipe and reimage — do not attempt decryption without validated backups.

2

Block Malicious IPs & Domains

Finding: Multiple C2 servers identified. Block 194.87.234.129, 198.105.121.50, 139.59.160.143 and domains spotsbill.com, tyu.benme.com at perimeter firewall and DNS.

3

Disable Adobe Flash Player

Finding: Flash exploit used by RIG EK. Flash is the primary attack vector. Disable or remove Flash Player across all endpoints — it reached end-of-life in December 2020.

4

Block .exe Downloads via HTTP

Finding: Malware delivered unencrypted. Implement HTTP content inspection to block application/x-msdownload transfers. Enforce HTTPS-only browsing policies.

5

Enable DNS Filtering for .top TLD

Finding: Ransomware used .top domain. Alert on or block first-seen .top domain queries. The .top TLD is heavily abused and rarely required by legitimate end users.

6

Conduct Enterprise-Wide IOC Sweep

Finding: Cerber may have spread via shared drives. Search all endpoints for Cerber artifacts (encrypted file extensions, registry persistence keys) using extracted IOCs.

References

Tools, documentation, and authoritative sources

Emerging Threats Ruleset (2025)

ET EXPLOIT_KIT RIG EK URI Struct / ET MALWARE Ransomware/Cerber / ET MALWARE DNS Domain Lookup — Suricata IDS signatures used for alert triage.

VirusTotal (2025)

IP and domain analysis reports for: 194.87.234.129, 139.59.160.143, 5.188.223.104, 198.105.121.50, p27dokhpz2n7nvgr.1jw2lx.top, benme.com, spotsbill.com.

MITRE ATT&CK Framework (2025)

T1189: Drive-by Compromise; T1203: Exploitation for Client Execution; T1071: Application Layer Protocol; T1486: Data Encrypted for Impact; TA0040: Impact.

Cisco Talos Intelligence Group

RIG Exploit Kit — threat summary, indicators, and C2 infrastructure documentation. Available at: talosintelligence.com

Wireshark Foundation (2025)

Wireshark Display Filter Reference and HTTP Object Export documentation. Available at: wireshark.org

BlockCypher Blockchain API (2025)

Bitcoin address and transaction lookup for wallet 17gd1msp5FnMcEMF1MitTNSsYs7w7AQyCt. Available at: api.blockcypher.com

Security Onion Solutions (2025)

Security Onion 2.4 documentation — Alerts, Hunt, and PCAP analysis modules. Available at: securityonionsolutions.com

NetworkMiner — Netresec (2025)

Network Forensic Analysis Tool — host enumeration, file extraction, and OS fingerprinting. Available at: netresec.com